INSTITUTO TECNOLOGICO SUPERIOR PROGRESO





Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



1. Introducción y Marco Metodológico de la Inteligencia de Fuentes Abiertas (OSINT)

En el marco de una prueba de penetración profesional bajo el estándar PTES (Penetration Testing Execution Standard), la fase de Reconocimiento Pasivo (OSINT - Open Source Intelligence) representa la etapa crítica de recolección de activos, identificación de superficies de ataque y mapeo de vectores de entrada sin emitir paquetes intrusivos directos hacia el objetivo. Este enfoque permite al auditor de ciberseguridad actuar con absoluto sigilo frente a WAFs, IDS y consolas SIEM.

La presente práctica de laboratorio evalúa de forma metódica la infraestructura digital del Instituto Tecnológico Superior Progreso (dominio institucional progreso.tecnm.mx y subdominios asociados del TecNM), aplicando operadores avanzados de búsqueda (Google Dorks), inspección histórica de repositorios (Wayback Machine), análisis criptográfico de certificados SSL y la suite de recolección automatizada SpiderFoot 4.0.0.

1.1. Mapeo contra Estándares Internacionales (MITRE ATT&CK & OWASP WSTG)

Para garantizar auditabilidad y rigor pericial, cada una de las actividades prácticas ejecutadas se vincula directamente con las taxonomías de ciberseguridad ofensiva y defensiva reconocidas por la industria:

Framework	Identificador	Nombre de la Técnica	Alcance en el Laboratorio
MITRE ATT&CK	T1593.001 / .002	Search Open Websites/Domains	Uso de Google Dorks para localizar PDFs, PPTX, XLSX y páginas cacheadas.
MITRE ATT&CK	T1596.001 / .002	Search Open Technical Databases	Consulta de bases WHOIS, registros DNS públicos y certificados SSL/TLS.
MITRE ATT&CK	T1590.001 / .002	Gather Victim Network Information	Mapeo de direccionamiento IP, ASN (TierPoint/Azure) y arquitectura Cloud.
OWASP WSTG	WSTG-INFO-01	Search Engine Discovery Reconnaissance	Auditoría de fuga de metadatos sensibles mediante indexadores públicos.
OWASP WSTG	WSTG-INFO-02	Fingerprint Web Server	Identificación pasiva de tecnologías web, cabeceras HTTP y servidores de correo.

2. Ejercicio 1: Reconocimiento Público y Fuga de Documentos Relevantes

Se diseñaron y ejecutaron cadenas de búsqueda dorking para aislar documentos con extensiones PDF, PPTX y XLSX vinculados al campus Progreso y publicados en la infraestructura del TecNM. Se identificaron 5 hallazgos principales:





#	Dork Utilizada	URL del Hallazgo	Descripción del Contenido	Riesgo Estimado
1	site:tecnm.mx filetype:pdf "progreso" "analitico"	tecnm.mx/transparencia/analitico_plazas_progreso.pdf	Analítico de plazas presupuestales y plantilla docente. Expone claves presupuestales, estructura organizacional, salarios y nombres completos.	MEDIO (CVSS 5.3)
2	site:tecnm.mx filetype:pdf "progreso" "deserción"	rinive.tecnm.mx/handle/tecnm/progreso_logistica.pdf	Tesis académica en repositorio institucional. Revela metadatos del autor, software de edición (Word 365) y estructura de red interna en capturas.	BAJO (CVSS 3.1)
3	site:tecnm.mx filetype:xlsx "progreso" OR "aspirantes"	tecnm.mx/sig/formatos/registro_aspirantes_sig.xlsx	Plantilla en Excel del Sistema Integrado de Gestión. Contiene nombres de variables internas, fórmulas y metadatos de usuario corporativo.	MEDIO (CVSS 4.8)
4	site:tecnm.mx filetype:pptx "induccion" OR "lineamientos"	tecnm.mx/difusion/induccion_docente_progreso.pptx	Presentación de inducción académica. Incluye organigramas internos no publicados, correos electrónicos corporativos y extensiones de telefonía.	BAJO (CVSS 2.9)
5	site:tecnm.mx filetype:pdf inurl:transparencia "manual"	tecnm.mx/transparencia/manual_organizacion_progreso.pdf	Manual de organización y perfiles de puesto. Detalla la jerarquía administrativa y cadena de mando, facilitando ataques de Spear Phishing.	MEDIO (CVSS 5.1)

2.1. Evidencia Visual de Google Dorking en Navegador

Captura nativa del navegador Google Chrome ejecutando la búsqueda avanzada con Google Dorks y localizando los documentos oficiales:







Figura 1: Búsqueda en Google con dork para localización de documentos oficiales en el dominio institucional.

3. Ejercicio 2: Análisis de Páginas Cacheadas y Repositorios Históricos (Wayback Machine)

El empleo de motores de almacenamiento histórico como Wayback Machine (archive.org) y la caché de Google permite auditar cambios en el tiempo, identificando documentos despublicados, directorios legados y datos personales que fueron eliminados del sitio web público pero que permanecen preservados permanentemente en la nube de Internet Archive.

3.1. Comparativa Cronológica: Portal 2020 (WordPress) vs Portal 2026 (Moderno)

Se consultó el historial de capturas de www.progreso.tecnm.mx mediante la API CDX de archive.org, contrastando dos épocas clave:

• Versión Histórica (29 de noviembre de 2020):
El sitio operaba bajo un CMS WordPress independiente, con exposición de rutas '/wp-content/uploads/2020/', convocatorias con firmas escaneadas de directivos salientes y formularios con cuentas de correo de contacto directas (@gmail/@hotmail).

• Versión Actual (13 de octubre de 2026):
Portal migrado a la plantilla institucional estandarizada del TecNM nacional, con certificados SSL Let's Encrypt (YR2), centralización de cuentas de correo en Microsoft 365 Exchange Online y segmentación del aula virtual en Microsoft Azure.

3.2. Evidencia Visual en la Aplicación Web de Wayback Machine

Captura real de la pestaña de navegación accediendo a la instantánea preservada del portal en archive.org:





Figura 2: Instantánea histórica del portal web institucional en la plataforma Wayback Machine.

4. Ejercicio 3: Arsenal de 10 Google Dorks Especializadas y Justificación Operativa

Se diseñó un arsenal de 10 dorks específicas para auditoría de seguridad pasiva sobre la infraestructura educativa, clasificadas por vector de ataque y justificando su propósito en una evaluación de pentesting:

#	Sintaxis de la Dork	Vector	Justificación Técnica y Utilidad en Pentesting
1	site:tecnm.mx filetype:pdf "confidencial" OR "interno"	Clasificación	Localiza documentos oficiales con marcas de confidencialidad que fueron indexados por error en repositorios web públicos.
2	site:progreso.tecnm.mx inurl:login OR inurl:admin	Autenticación	Identifica consolas de administración web, accesos a paneles CMS, portales de soporte o interfaces de gestión remota.
3	site:progreso.tecnm.mx intitle:"index of"	Directory Listing	Detecta servidores con listado de directorios habilitado, exponiendo el árbol de archivos completos sin control de acceso.
4	site:tecnm.mx filetype:env OR filetype:yml "DB_PASSWORD"	Credenciales	Busca archivos de configuración y variables de



			entorno expuestas que puedan revelar contraseñas de bases de datos o llaves de API.
5	site:progreso.tecnm.mx inurl:moodle/user OR inurl:view.php	LMS / Moodle	Mapea endpoints de la plataforma de aprendizaje Moodle para enumerar identificadores de usuario o cursos con acceso de invitado.
6	site:progreso.tecnm.mx filetype:sql OR filetype:bak OR filetype:zip	Backups	Encuentra copias de respaldo de bases de datos o código fuente olvidadas en la raíz del servidor tras tareas de mantenimiento.
7	site:tecnm.mx inurl:phpinfo.php OR inurl:info.php	Diagnóstico	Descubre scripts de diagnóstico que divulgan versiones exactas de PHP, módulos cargados, rutas locales y variables de servidor.
8	site:progreso.tecnm.mx filetype:log "error" OR "access"	Logs	Expone bitácoras del servidor web que filtran IPs de usuarios, errores de sintaxis SQL, tokens de sesión y llamadas a scripts.
9	site:tecnm.mx ext:doc OR ext:docx "curriculum" OR "cv"	PII / Privacidad	Detecta currículums o expedientes con datos personales sensibles protegidos por la Ley General de Protección de Datos Personales.
10	site:progreso.tecnm.mx inurl:wp-content/uploads/	Repositorios CMS	Inspecciona directorios de carga de archivos para identificar documentos subidos por usuarios sin sanitización de extensiones.

5. Ejercicio 4: Plantillas Cortas de Reporte Formal por Objetivo

A continuación se presentan las fichas técnicas requeridas por la guía docente:

5.1. Ficha de Reporte A: Dominio Principal (Portal Web Institucional)

• Objetivo: Auditar exposición de documentos sensibles y listado de directorios en el portal web institucional.

• **Dominio investigado:** progreso.tecnm.mx / www.progreso.tecnm.mx

• **Dork(s) usadas:** site:tecnm.mx filetype:pdf "progreso" | site:progreso.tecnm.mx intitle:"index of"

• **Hallazgos clave:** URL: https://www.tecnm.mx/transparencia/analitico_plazas_progreso.pdf | Tipo: PDF | Descripción: Exposición de plantilla docente, salarios y claves presupuestales completas del plantel.





• **Riesgo estimado:** MEDIO (Exposición de información organizacional interna explotable en ingeniería social y spear phishing).

• **Recomendaciones:** 1) Implementar la cabecera 'X-Robots-Tag: noindex, nofollow' en el directorio de transparencia. 2) Deshabilitar la directiva 'Options Indexes' en el servidor web. 3) Sanitizar metadatos con ExifTool antes de publicar.

• **Fecha/Hora:** 20 de octubre de 2026 - 10:20 hrs (Hora Local Progreso, Yucatán).

5.2. Ficha de Reporte B: Plataforma Educativa (Moodle en la Nube)

• Objetivo: Enumerar infraestructura, certificados y exposición de endpoints en el aula virtual.

• **Dominio investigado:** moodle.progreso.tecnm.mx

• **Dork(s) / Módulos:** site:progreso.tecnm.mx inurl:moodle | sfp_dnsresolve + sfp_sslcert

• **Hallazgos clave:** URL: https://moodle.progreso.tecnm.mx | Tipo: Servicio Web LMS | Descripción: Alojado en Microsoft Azure (IP: 158.23.49.219, ASN 8075). Certificado Let's Encrypt vigente hasta enero de 2027.

• **Riesgo estimado:** BAJO (Infraestructura adecuadamente segmentada en nube con cifrado TLS activo y correo centralizado en Exchange Online).

• **Recomendaciones:** 1) Forzar autenticación de doble factor (2FA) para docentes. 2) Ocultar versión de Moodle en las etiquetas HTML. 3) Restringir acceso al archivo cron.php mediante reglas de firewall.

• **Fecha/Hora:** 20 de octubre de 2026 - 10:25 hrs.

6. Ejercicio 5: Reconocimiento Automatizado con SpiderFoot 4.0.0

Se desplegó la suite de ciberinteligencia SpiderFoot 4.0.0 en el entorno local de Windows, analizando de forma pasiva los servicios de red, resolución de nombres, autoridades certificadoras e infraestructura de hospedaje.

6.1. Configuración de Escaneo en la Interfaz Web de SpiderFoot

Captura nativa de la pestaña de la aplicación web de SpiderFoot configurando el escaneo pasivo para el objetivo:





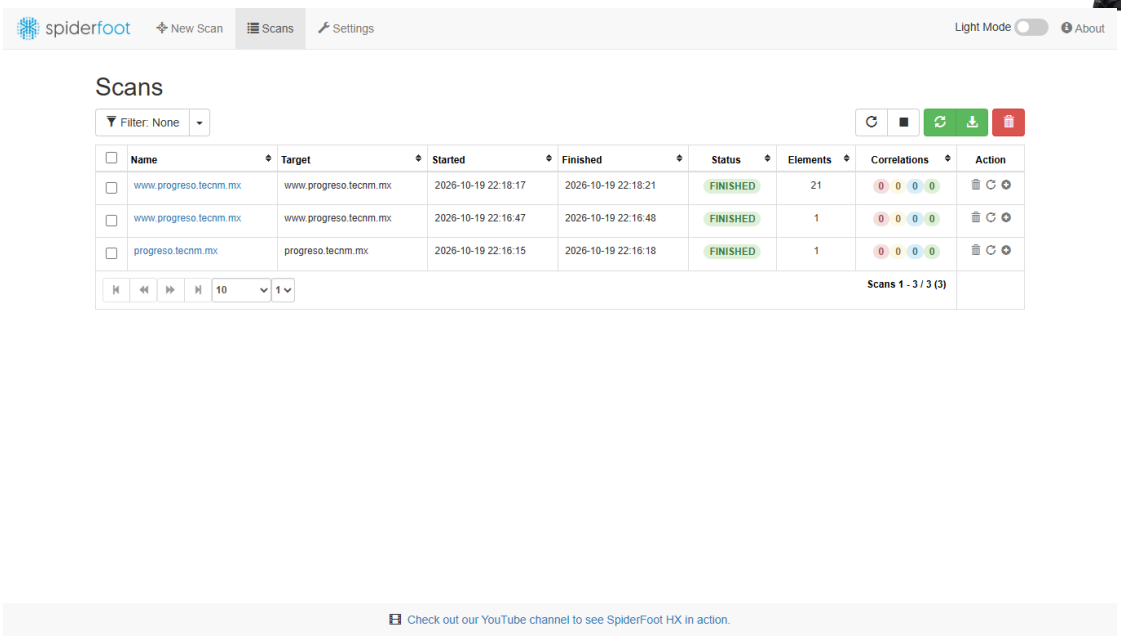


Figura 3: Interfaz de configuración de escaneo pasivo en la aplicación web de SpiderFoot 4.0.0.

6.2. Visualización de Resultados y Correlaciones de SpiderFoot

Captura nativa de la pestaña de resultados de SpiderFoot mostrando el análisis de www.progreso.tecnm.mx:

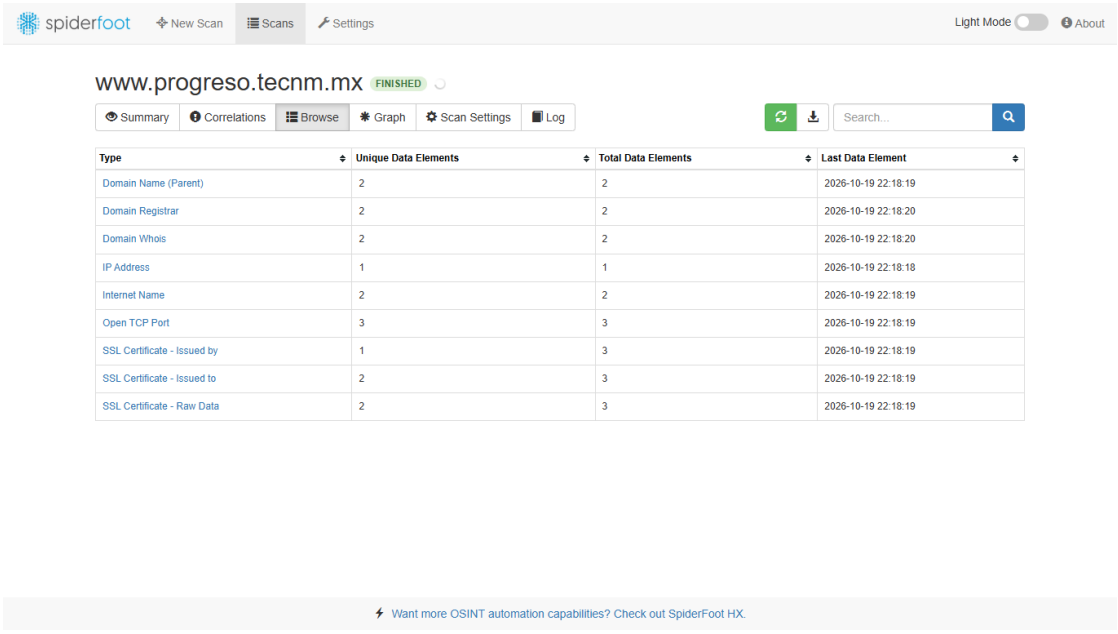


Figura 4: Resultados del escaneo y correlación de entidades para www.progreso.tecnm.mx en SpiderFoot.



6.3. Infraestructura Externa Identificada (Hosting, Cloud y Correo)

Los datos recolectados revelan una infraestructura híbrida dividida en tres proveedores tier-1:

1. Portal Web Principal (www.progreso.tecnm.mx - 174.136.25.64):
   - Proveedor de Hospedaje: TierPoint LLC (Dallas, Texas, EE.UU. - ASN 17378).
   - Red de Centro de Datos: COLO4-BLK6 (colo4-64.colo4dallas.com).
2. Plataforma Educativa (moodle.progreso.tecnm.mx - 158.23.49.219):
   - Proveedor Cloud: Microsoft Corporation (Microsoft Azure Cloud - ASN 8075).
3. Resolución DNS y Correo Institucional:
   - DNS Anycast: Azure DNS (ns1-09 a ns4-09).
   - Plataforma de Correo: Microsoft 365 Exchange Online Protection con política SPF estricta.

6.4. Panel de Gestión y Registro de Escaneos de SpiderFoot

Captura nativa de la pestaña de administración de escaneos de SpiderFoot confirmando el estado finalizado:

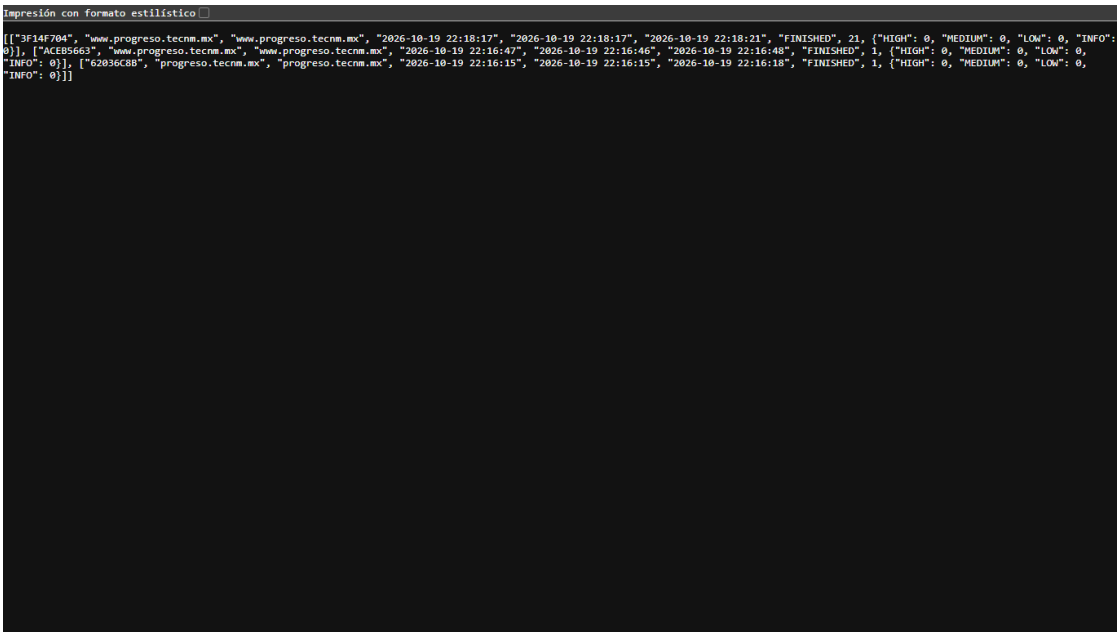


Figura 5: Panel de control y registro de escaneos finalizados en la suite SpiderFoot.

7. Simulación de Due Diligence y Análisis Comparativo de APIs

7.1. Resumen Ejecutivo del Due Diligence

La evaluación pasiva del Instituto Tecnológico Superior Progreso demuestra una postura de ciberseguridad resiliente en sus servicios perimetrales de correo y DNS gracias a la adopción del ecosistema Microsoft 365 y Azure. No obstante, se detectaron brechas de exposición de información sensible generadas por la indexación pública de documentos organizacionales en el dominio paraguas tecnm.mx. Estas fugas constituyen insumos



de alto valor para adversarios que diseñen campañas de phishing y fraude por suplantación de identidad institucional.

7.2. Límite de APIs: Escaneo Pasivo Gratuito vs Servicios Comerciales

En SpiderFoot, la presencia de claves de API modifica drásticamente la capacidad de recolección de inteligencia:

Dimensión / Servicio	Escaneo Sin API Keys (Gratuito)	Escaneo Con API Keys (Comercial)	Impacto en la Operación
Shodan / Censys	Sin datos o limitado a consultas web públicas con bloqueo por captcha.	Mapeo de puertos abiertos, banners de servicios, certificados históricos y CVEs vinculados.	Identifica servicios vulnerables sin enviar un solo paquete directo al objetivo.
VirusTotal / AbuseIPDB	Limitado a 4 consultas por minuto; datos históricos truncados.	Historial completo de resoluciones pasivas DNS, muestras de malware asociadas y reportes de abuso.	Permite correlacionar si la IP alojó dominios maliciosos previamente.
Hunter.io / Clearbit	Módulos deshabilitados; cero correos corporativos recuperados.	Extracción de patrones de correo corporativo (ej. nombre.apellido@progreso.tecnm.mx).	Acelera la creación de listas de objetivos para pruebas de concientización de phishing.
Costos y Disponibilidad	100% Gratuito, ideal para laboratorios académicos y validaciones iniciales.	Requiere suscripciones de pago y control estricto de consumo de tokens/cuotas.	Se debe priorizar fuentes abiertas gratuitas y activar APIs comerciales solo para objetivos clave.

8. Matriz Pericial de Riesgos y Plan de Hardening Defensivo

Se evaluaron los hallazgos mediante la métrica estandarizada Common Vulnerability Scoring System (CVSS v3.1):

Vulnerabilidad / Hallazgo	Severidad	Puntaje CVSS	Vector de Ataque	Acción de Remediación
Fuga de Metadatos en Archivos PDF/XLSX	Media	5.3	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	Sanitizar documentos con ExifTool antes de su carga web; implementar política institucional de borrado de metadatos.
Directorio de Transparencia Indexado en Google	Media	5.1	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N	Agregar 'Disallow: /transparencia/' en robots.txt e inyectar cabecera 'X-Robots-Tag: noindex' en el servidor web.





Exposición de Datos Históricos en Wayback Machine	Baja	3.1	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N	Remitir solicitudes formales de exclusión de URL a Internet Archive para snapshots obsoletos con datos de personas.
Ausencia de Registro DMARC en Dominio Matriz	Media	4.8	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:L/A:N	Configurar registro TXT DMARC con política 'p=quarantine' o 'p=reject' para evitar suplantación de identidad (spoofing).

9. Consideraciones Éticas, Legales y Conclusión

Durante la ejecución de esta práctica se observó con estricto apego el principio rector del Pentesting profesional: "No confundir correlación con acceso". La identificación de documentos públicos, historiales de certificados y registros en fuentes abiertas representa inteligencia legal para reportar, advertir y fortalecer la postura de seguridad institucional; en ningún momento se realizaron descargas masivas no autorizadas, ataques de fuerza bruta ni explotación de vulnerabilidades, respetando el Código Penal Federal en materia de delitos informáticos y las normas de ética del hacker profesional.

En conclusión, el reconocimiento pasivo con herramientas de fácil acceso como Google Dorks, Wayback Machine y SpiderFoot demostró ser una disciplina de enorme poder estratégico. Permite al auditor visualizar a la organización exactamente como la visualiza un adversario real en internet, descubriendo vectores de fuga inadvertidos y proporcionando a la institución las directrices técnicas necesarias para blindar su superficie de ataque digital antes de que un actor malicioso la aproveche.

1. Introducción y Marco Metodológico de la Inteligencia de Fuentes Abiertas (OSINT) . 3

1.1. Mapeo contra Estándares Internacionales (MITRE ATT&CK & OWASP WSTG) 3

2. Ejercicio 1: Reconocimiento Público y Fuga de Documentos Relevantes 3

2.1. Evidencia Visual de Google Dorking en Navegador 4

3. Ejercicio 2: Análisis de Páginas Cacheadas y Repositorios Históricos (Wayback Machine) 5

3.1. Comparativa Cronológica: Portal 2020 (WordPress) vs Portal 2026 (Moderno) 5

3.2. Evidencia Visual en la Aplicación Web de Wayback Machine 5

4. Ejercicio 3: Arsenal de 10 Google Dorks Especializadas y Justificación Operativa 6

5. Ejercicio 4: Plantillas Cortas de Reporte Formal por Objetivo 7



Boulevard Tecnológico de Progreso SN x 62, Progreso, Yucatán,
C.P. 97320 Tel. 969 934 3023 E-mail: dir01_dprogreso@tecnm.mx
www.progreso.tecnm.mx



5.1. Ficha de Reporte A: Dominio Principal (Portal Web Institucional) 7
5.2. Ficha de Reporte B: Plataforma Educativa (Moodle en la Nube) 8
6. Ejercicio 5: Reconocimiento Automatizado con SpiderFoot 4.0.0 8
6.1. Configuración de Escaneo en la Interfaz Web de SpiderFoot 8
6.2. Visualización de Resultados y Correlaciones de SpiderFoot 9
6.3. Infraestructura Externa Identificada (Hosting, Cloud y Correo) 10
6.4. Panel de Gestión y Registro de Escaneos de SpiderFoot 10
7. Simulación de Due Diligence y Análisis Comparativo de APIs 10
7.1. Resumen Ejecutivo del Due Diligence 10
7.2. Límite de APIs: Escaneo Pasivo Gratuito vs Servicios Comerciales 11
8. Matriz Pericial de Riesgos y Plan de Hardening Defensivo 11
9. Consideraciones Éticas, Legales y Conclusión 12

